Entry Information

ID:
AML.CS0030

Type:
Case-Study

Name:
LLM Jacking

URL:
https://atlas.mitre.org/studies/AML.CS0030/

Incident Date:
2024-05-06

Target:
Cloud-Based LLM Services

Actor:
Unknown

Description

The Sysdig Threat Research Team discovered that malicious actors utilized stolen credentials to gain access to cloud-hosted large language models (LLMs). The actors covertly gathered information about which models were enabled on the cloud service and created a reverse proxy for LLMs that would allow them to provide model access to cybercriminals.

The Sysdig researchers identified tools used by the unknown actors that could target a broad range of cloud services including AI21 Labs, Anthropic, AWS Bedrock, Azure, ElevenLabs, MakerSuite, Mistral, OpenAI, OpenRouter, and GCP Vertex AI. Their technical analysis represented in the procedure below looked at at Amazon CloudTrail logs from the Amazon Bedrock service.

The Sysdig researchers estimated that the worst-case financial harm for the unauthorized use of a single Claude 2.x model could be up to $46,000 a day.

Update as of April 2025: This attack is ongoing and evolving. This case study only covers the initial reporting from Sysdig.

Attack Procedure:
[AML.T0049] Exploit Public-Facing Application: The adversaries exploited a vulnerable version of Laravel ([CVE-2021-3129](https://www.cve.org/CVERecord?id=CVE-2021-3129)) to gain initial access to the victims' systems.
[AML.T0055] Unsecured Credentials: The adversaries found unsecured credentials to cloud environments on the victims' systems
[AML.T0012] Valid Accounts: The compromised credentials gave the adversaries access to cloud environments where large language model (LLM) services were hosted.
[AML.T0016.001] Software Tools: The adversaries obtained [keychecker](https://github.com/cunnymessiah/keychecker), a bulk key checker for various AI services which is capable of testing if the key is valid and retrieving some attributes of the account (e.g. account

balance and available models).
[AML.T0075] Cloud Service Discovery: The adversaries used keychecker to discover which LLM services were enabled in the cloud environment and if the resources had any resource quotas for the services.

Then, the adversaries checked to see if their stolen credentials gave them access to the LLM resources. They used legitimate `invokeModel` queries with an invalid value of -1 for the `max_tokens_to_sample` parameter, which would raise an `AccessDenied` error if the credentials did not have the proper access to invoke the model. This test revealed that the stolen credentials did provide them with access to LLM resources.

The adversaries also used `GetModelInvocationLoggingConfiguration` to understand how the model was configured. This allowed them to see if prompt logging was enabled to help them avoid detection when executing prompts.
[AML.T0016.001] Software Tools: The adversaries then used [OAI Reverse Proxy](https://gitgud.io/khanon/oai-reverse-proxy) to create a reverse proxy service in front of the stolen LLM resources. The reverse proxy service could be used to sell access to cybercriminals who could exploit the LLMs for malicious purposes.
[AML.T0048.000] Financial Harm: In addition to providing cybercriminals with covert access to LLM resources, the unauthorized use of these LLM models could cost victims thousands of dollars per day.

References

- LLMjacking: Stolen Cloud Credentials Used in New AI Attack — https://sysdig.com/blog/llmjacking-stolen-cloud-credentials-used-in-new-ai-attack/

- The Growing Dangers of LLMjacking: Evolving Tactics and Evading Sanctions — https://sysdig.com/blog/growing-dangers-of-llmjacking/

- LLMjacking targets DeepSeek — https://sysdig.com/blog/llmjacking-targets-deepseek/

- AIID Incident 898: Alleged LLMjacking Targets AI Cloud Services with Stolen Credentials — https://incidentdatabase.ai/cite/898